

1. Consider the email security solutions currently employed on the Internet. If a certain domain is using DKIM (DomainKeys Identified Mail), does this make the use of S/MIME by the users of the same domain unnecessary? Justify your answer.

No, DKIM does not make S/MIME unnecessary.

- DKIM authenticates the sending domain, ensuring that the email header and body haven't been tampered with since leaving the initial mail server that applied the signature. It provides integrity and domain origin authentication.
- However, DKIM does not provide confidentiality. The content of a DKIM-signed email is still sent in plaintext and can be read by anyone who intercepts it. While it ensures the message arrived unaltered from the domain, it doesn't prevent eavesdropping.
- S/MIME, on the other hand, provides end-to-end confidentiality by encrypting the message content using the recipient's public key. This ensures that only the intended recipient can read the email. S/MIME also provides stronger authentication and non-repudiation specifically for the individual user sending the message content, not just the domain, which DKIM does not guarantee.

Therefore, even if a domain uses DKIM to verify the source domain and message integrity at a transport level, users who require confidentiality for their email content (to prevent eavesdropping) or strong user-level authentication and non-repudiation for sensitive messages would still need to use S/MIME. The two protocols address different layers and aspects of email security and are often used together for a more comprehensive defense.

No, a domain using DKIM does not make S/MIME unnecessary for its users. DKIM authenticates the sending domain and ensures message integrity by verifying that the email originates from an authorized server and has not been altered in transit. However, DKIM does not provide confidentiality; the email content remains unencrypted and vulnerable to eavesdropping. S/MIME provides end-to-end confidentiality (encryption) for the message content, ensuring only the intended recipient can read it. It also offers strong user-level authentication, integrity, and non-repudiation for the message itself. Thus, S/MIME is still necessary for users requiring confidential communication and user-specific message security, which DKIM does not provide.

2. Consider the DES (Data Encryption Standard) symmetric encryption algorithm. What is the relationship between the avalanche effect exhibited by this algorithm and the principles defined in Feistel's structure to make cryptanalysis attacks more difficult? Justify your answer.

Principles of Diffusion and Confusion

Claude Shannon introduced the concepts of diffusion and confusion as fundamental building blocks for cryptographic systems, aiming to thwart cryptanalysis based on statistical analysis.

- Diffusion:** This principle seeks to dissipate the statistical structure of the plaintext into long-range statistics of the ciphertext. It ensures that each plaintext digit affects the value of many ciphertext digits. In modern block ciphers like AES, diffusion is achieved through techniques like substitution-permutation networks (SPN) and mixing operations. In DES, permutation operations (like P-boxes) contribute to diffusion.

- Confusion:** This principle focuses on making the relationship between the ciphertext, plaintext, and encryption key as complex and obscure as possible. The goal is to prevent attackers from deducing the key even with statistical data of the ciphertext. Confusion is typically achieved through nonlinear transformations, such as substitution boxes (S-boxes). In DES, the S-boxes provide this non-linearity.

The Avalanche Effect

A desirable property for any encryption algorithm is the avalanche effect. This effect ensures that a tiny change in the input (either plaintext or key), even a single bit, drastically alters the output (ciphertext). If a change were small, it could provide a way to reduce the search space for cryptanalysis. Modern algorithms like AES and SHA-256 exhibit this property strongly. DES was also shown to exhibit a strong avalanche effect, where a single-bit change in either the plaintext or the key resulted in roughly half of the ciphertext bits changing.

Relationship and Justification

The Feistel structure, as implemented in DES, directly supports the principles of diffusion and confusion, and the combination of these principles over multiple rounds is what produces the desirable avalanche effect.

The **alternating rounds of substitution and permutation** within the Feistel structure are designed to spread the influence of plaintext bits across the ciphertext (diffusion) and obscure the relationship between the key and ciphertext (confusion).

Specifically in DES:

- The S-boxes (substitution) introduce non-linearity and contribute significantly to confusion.
 - The permutations (like P-boxes) spread the bits around, contributing to diffusion.
 - The multiple rounds ensure that these effects are amplified, so the influence of a single input bit or key bit is spread throughout the entire block.
- This iterative application of confusion and diffusion in each round, as facilitated by the Feistel design, ensures that a small change in the input (plaintext or key) is rapidly propagated and mixed throughout the block, resulting in a drastically different output block. This is the avalanche effect.

Justification: The avalanche effect makes cryptanalysis difficult because it eliminates predictable patterns and obscures the relationship between the input, key, and output. If a cryptanalyst tries to deduce the key or plaintext by observing changes in the ciphertext based on known or guessed inputs, the strong avalanche effect means even tiny differences in the input lead to essentially random, large differences in the output. This randomness in the output change prevents the cryptanalyst from gaining useful statistical information or finding discernible patterns that could reveal the key or plaintext structure. Therefore, the design principles of diffusion and confusion, embodied in the Feistel structure's rounds, are specifically intended to create this strong

avalanche effect, which in turn serves as a fundamental defense against cryptanalytic attacks.

While DES is considered obsolete due to its short 56-bit key length, making it vulnerable to brute-force attacks, the structure itself and its exhibition of diffusion, confusion, and the avalanche effect were considered robust at the time.

3. Consider the CBC (Cipher Block Chaining) mode of block encryption. In this mode, is it advisable to reuse a certain IV (Initialization Vector) value with the same encryption key? Justify your answer.

It is not advisable to reuse a certain IV (Initialization Vector) value with the same encryption key when using the CBC (Cipher Block Chaining) mode of block encryption.

Here's the justification, drawing from the sources:

- CBC is one of several modes of operation for symmetric block ciphers like DES or AES.
- An Initialization Vector (IV) is a value used alongside the encryption key in certain modes, including CBC, to randomize the encryption process. Its main purpose is to ensure that the same plaintext encrypted multiple times results in different ciphertexts.
- The IV helps to add randomness, which prevents patterns from appearing in the output.
- In CBC mode, even if a plaintext block is repeated later in the message, the output ciphertext block will be different because of the chaining mechanism involving the previous ciphertext block and the IV for the first block.
- The sources explicitly state that while the IV itself is not secret, it must be unique (and sometimes random) for each encryption operation to maintain security.
- Using a random and **UNIQUE** IV is important for ensuring the security of block cipher modes and helps to prevent certain types of attacks that rely on repeating patterns in the ciphertext.

Therefore, reusing an IV with the same key would violate the requirement for a unique IV. This would allow an attacker to potentially identify when the same plaintext block is encrypted at the beginning of a message or sequence, as the initial output would be identical given the same IV and key. This defeats the purpose of the IV, which is to prevent such observable patterns and protect against attacks that exploit them.

4. Consider the RSA algorithm. Demonstrate the operation of this algorithm, considering the usage of the two prime numbers $p=7$ and $q=13$ and the encryption of a message represented by the number "2".

$$\begin{aligned}
 n &= 91 \\
 \phi(n) &= 6 \times 12 = 72 \\
 e &= 7 \rightarrow \text{gcd}(7, 72) = 1 \\
 d \times e &= 1 \pmod{72} \Rightarrow 7 \times 41 = 1 \pmod{72} \Rightarrow d = 41 \\
 PK &= (7, 91) \\
 PR &= (41, 91) \\
 M &= 2 \\
 M^e \pmod n &= 2^7 \pmod{91} = 128 \pmod{91} = 37
 \end{aligned}$$

5. Consider the IPsec protocol, the ESP security header, and the tunnel operation mode. Describe an application scenario where two VPN tunnels with encryption (both tunnels using the ESP header) are invalidly combined. Justify your answer.

Imagine a setup where Alice is a host inside network A and Bob is a host inside network B. Both networks have their respective VPN gateways: GW1 on Alice's side and GW2 on Bob's side. Two IPsec VPN tunnels are configured using ESP in tunnel mode with encryption. However, instead of configuring a single tunnel between the gateways (GW1 to GW2), the system administrator mistakenly creates two separate tunnels: one from Alice directly to Bob (a host-to-host ESP tunnel), and another from GW1 to GW2 (a gateway-to-gateway ESP tunnel).

As a result, when Alice sends a packet, her device encrypts it using ESP, creating an outer IP header and ESP payload. Then, as this encrypted packet exits network A through GW1, the gateway encrypts it again using another ESP tunnel before forwarding it toward GW2. The problem arises when GW2 receives the packet: it decrypts only the outer ESP layer but is unaware that the resulting payload is still an ESP-encrypted packet originally intended for Bob. It forwards this encrypted payload to Bob, who, in turn, expects either a plaintext packet or a single ESP layer. Since the packet still contains an ESP-encrypted payload he cannot process—due to lacking the necessary Security Association (SA)—Bob is unable to decrypt or interpret the message.

This scenario is invalid because ESP in tunnel mode is designed to protect the entire IP packet between clearly defined endpoints. When two ESP tunnels are applied independently by devices that do not coordinate or share keys, the system breaks. The second tunnel treats the first encrypted payload as opaque data, and the final recipient cannot decrypt it. There is no chaining of SAs, and no nested encapsulation to preserve the integrity of the encryption hierarchy.

In summary, this configuration fails because the two tunnels operate without knowledge of each other and apply encryption at different layers without proper nesting. This leads to a situation where packets are doubly encrypted, but no single endpoint has the full capability to decrypt and interpret the message. For correct operation, the ESP tunnel should be established between gateways GW1 and GW2, or—if two layers of encryption are truly needed—they must be explicitly nested with appropriate SA management.

6. Why MAC (Message Authentication Code) codes cannot guarantee non-repudiation? Justify your answer.

MACs (Message Authentication Codes) cannot guarantee non-repudiation because they rely on a shared secret key between the sender and receiver. Since both parties know the key used to create the MAC, the receiver cannot prove to a third party that the sender, and only the sender, generated the MAC; the receiver could have generated it themselves using the shared key. Non-repudiation, which prevents denial of sending, requires a mechanism where only the sender could have created the proof of origin, a property provided by digital signatures which use the sender's unique private key.

7. Consider the Kerberos Protocol. Why, in this protocol, the system clock of the various participating hosts must be synchronized or, at best, with a small deviation between them? Justify your answer.

Here's the justification drawing from the sources:

1. **Kerberos uses Timestamps for Freshness:** The Kerberos authentication model involves steps where a client sends requests to the **Ticket Granting Server (TGS)** and then to the Service. These requests include an authenticator. This authenticator contains a timestamp. The purpose of this timestamp is to prove the client's identity and freshness. Tickets obtained from the **Authentication Server (AS)** also contain a timestamp and a lifetime parameter.
2. **Replay Attacks:** A replay attack is a type of active attack that "involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect". Timestamps and lifetimes in Kerberos are used to detect and prevent these attacks [22, 23, 212 (general KDC context)].
3. **Impact of Unsynchronized Clocks:** If the clocks between the client, the Kerberos servers (AS and TGS), and the application service are not synchronized, the timestamp-based freshness checks fail. Therefore, synchronized clocks ensure that the timestamps and lifetimes embedded in authenticators and tickets are reliable indicators of freshness, which is essential for the Kerberos protocol to effectively thwart replay attacks.